INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — AYSABAND 6 Kenar Bantlama Makinesi

Tüm laboratuvarlar gün boyu gelişen tek bir örnek makine — AYSABAND 6 kenar bantlama makinesi — üzerinde işlenir.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

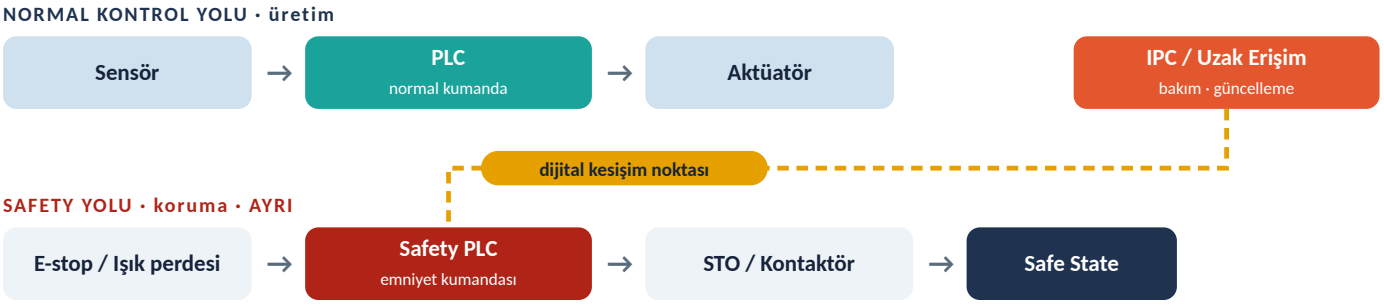
LABORATUVAR 1 · AYSABAND 6 · Kenar Bantlama Makinesi

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Kesici/freze ve testere ünitelerinin dönen takımları (kesilme, uzuv kaybı); sıcak tutkal potası (yanık); besleme zinciri ve basınç barı (ezilme/sıkışma); panel geri tepmesi; odun tozu (solunum, yangın/toz patlaması) ve gürültü. Zarar gören: el-parmak, kol, göz, solunum yolu.

2 Safety function (emniyet fonksiyonu) hangisidir?

SF1 Acil stop: besleme zinciri ve kesici miller durur/frenlenir. SF2 Kaput/koruyucu kapak interlock: kapak açıkken kesici ve besleme çalışmaz; miller tam durana kadar kapak kilitli kalır. SF3 Emiş devrede değilse kesici üniteler çalışmaz (toz). SF4 Giriş/çıkış bölgesi koruması ihlalinde besleme durur (varsayım).

3 Safety-related control system nerede? Şemada işaretleyin.

E-stop butonları (giriş/çıkış/operatör) + kaput interlock şalterleri → Safety PLC / emniyet rölesi → STO / kontaktör (besleme zinciri, freze-testere sürücüleri, fren) + pnömatik emniyet valfi. Şemada SAFETY YOLU satırındaki üç kutu işaretlenir: Safety PLC, STO/Kontaktör, Safe State.

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi yönetir (besleme hızı, ünite pozisyonları, bant/reçete seçimi, tutkal sıcaklığı); arızası üretimi bozar. Safety PLC sertifikalı, çift kanallı, kendini diagnostik eder ve hatada güvenli duruma gider; yazılımı/parametreleri ayrı korunur, normal PLC'den değiştirilemez.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

Gerekli güvenilirliği riske orantılı tanımlar. Dönen kesicilere temasın ağır yaralanma yaratabildiği bu makinede E-stop ve kaput kilitleme için tipik hedef PLr d / SIL 2 (nihai değer risk analiziyle belirlenir). Önemli: güvenilirlik donanım + dijital konfigürasyona bağlıdır; durma/frenleme parametreleri bozulursa PLr korunmaz.

6 Safe state (güvenli durum) nedir?

Besleme zinciri durmuş, kesici miller frenlenmiş/durmuş (STO + fren), pnömatik elemanlar güvenli konumda, tutkal ısıtıcısı sınır sıcaklıkta. Dikkat: miller tam durmadan kapak açılamaz (kilit); emiş toz boşalana kadar çalışmaya devam edebilir.

7 Safety function hangi dijital bağımlılıklara sahip?

Safety PLC konfigürasyonu/parametreleri (mühendislik yazılımı), sürücü STO ve frenleme/durma süresi parametreleri, firmware, HMI'dan reset/bypass komutları ve reçete (ünite pozisyonları, hız), USB/ERP ile gelen iş dosyaları, mühendislik laptopu, uzak servis erişimi, emiş interlock sinyali.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

(1) Uzak servis erişimi / ortak servis hesabı → PLC/HMI → kaput interlock bypass'ı ya da frenleme/durma süresi parametresi değişikliği. (2) USB/ERP iş dosyası → ünite pozisyonu/hız parametresi bozulur. (3) Mühendislik laptopu → Safety PLC konfigürasyonu/firmware değişikliği. (4) HMI'dan reset/bypass yetkisinin kötüye kullanımı.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · AYSABAND 6 · Kenar Bantlama Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI · Robot kontrolörü · **Safety PLC** · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı (ERP/e-posta)

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Z1 Safety: Safety PLC, E-stop, kaput kilitleri, STO/fren. Z2 Kontrol: PLC, servo ünite kontrolörleri (freze/testere/kazıma), besleme zinciri sürücüsü, tutkal sıcaklık kontrolü, pnömatik, emiş kontrolü. Z3 Operasyon: HMI, SCADA/MES istemcisi, mühendislik istasyonu (USB). Z4 Uzak servis/DMZ: jump server + VPN geçidi. Z5 Kurumsal: ofis ağı (ERP/CAD-CAM/e-posta).

2 Safety PLC'yi hangi bölgeye koydunuz — neden?

Tek başına Z1: en kritik varlık, insan güvenliğini taşıyor; normal ağdan ve uzak erişimden ayrı, sert kablolu emniyet sinyalleri + tek yönlü durum bilgisi. Yazma/konfigürasyon yalnızca yerelden yapılır.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

C1 Z1↔Z2: sert kablolu sinyal, ağdan yazma yok, sadece durum okuma. C2 Z2↔Z3: güvenlik duvarı, gerekli portlar, rol bazlı HMI yetkisi. C3 Z3↔Z4: jump server, MFA, oturum kaydı, onaylı zaman penceresi. C4 Z4↔Z5: izinli liste, doğrudan PLC erişimi yok. C5 Mühendislik→Z1: yalnızca yerel, anahtar+şifre, değişiklik kaydı.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server — tek kontrol ve kayıt noktası; doğrudan erişim saldırı yüzeyini büyütür.
Tünel?	Açık / VPN	VPN — şifreli ve kimlikli kanal; açık bağlantı dinlenir/taranır.
Kimlik?	Parola / MFA	MFA — çalınan parola tek başına yetmesin.
Hesap?	Paylaşılan / Kişisel	Kişisel — paylaşılan hesapta sorumluluk ve kanıt yoktur.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı — olay sonrası kanıt ve CRA bildirimi için gerekli.
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı — onaylı serviste süreli açılır, iş bitince kapanır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış saldırgan → uzak servis girişi (zayıf/ortak hesap) → PLC/HMI → kaput interlock bypass'ı veya frenleme süresi parametresi değişikliği → operatör açık kaputtan dönen kesiciye temas: kesilme/uzuv kaybı	3	3	2	18	KRİTİK
Manipüle iş/reçete dosyası (USB/ERP) → ünite pozisyonu/hız parametresi bozulur → kesici operatöre beklenmedik yaklaşır veya panel geri teper → yaralanma	2	3	2	12	YÜKSEK (S=3)
Zararlı USB/laptop → Safety PLC konfigürasyon/firmware değişikliği → kapak kilidi/durma fonksiyonu devre dışı veya gecikmeli → kesici/zincir yaralanması	1	3	1	3	DÜŞÜK → S=3 ÖNE

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

Senaryo 1: uzak erişim olası (L3) ve kapak açıkken dönen kesici operatörü ciddi yaralayabilir (S3); skor 18 = Kritik.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet, Senaryo 3 (skor 3 = Düşük ama S=3). Risk Register'da 'S=3 – insan güvenliği' bayrağıyla ayrı listelenir; skora bakılmaksızın aksiyon, sorumlu ve tarih atanır; yönetim özetinde görünür kalır.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · AYSABAND 6 · Kenar Bantlama Makinesi

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

Teknisyen/üretici internetten doğrudan servis/uzaktan erişim modülüne bağlanıyor (varsayım). Tek ortak servis hesabı, parola tabanlı; tünel yok/yetersiz. Kayıt yok; erişim sürekli açık. Servis modülü ile ana PLC aynı düz ağda; Safety PLC'ye ağ yolu ihtimali var.

HEDEF (beş ilkeyle yeniden tasarlayın)

1 Ara nokta: tüm erişim jump server üzerinden. 2 VPN + MFA. 3 Kişisel hesap + tam oturum kaydı. 4 Varsayılan kapalı: talepli, onaylı, süreli açılır. 5 Bölümlendirme: uzak yol yalnızca Z2/Z3'e ulaşır; Z1 (Safety) erişilemez.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Hedef mimaride etkilenmemeli: Safety PLC ayrı zone'da, sert kablolu E-stop/kaput kilidi/STO-fren zinciri taşır ve konfigürasyon ağdan yazılamaz. Mevcut durumda etkilenebilir: ortak ağ ve servis hesabı üzerinden interlock/durma süresi parametresine erişim riski var. Bu yüzden iki katman da şart: erişim güvenliği + emniyet bağımsızlığı.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

   Emniyet fonksiyonu normal PLC, HMI, ağ ve uzak erişimin arızasından/ele geçirilmesinden bağımsız güvenli duruma geçebilmeli. Hiçbir uzak/ağ yolu emniyet parametre ve programını (kaput kilidi, durma/frenleme süresi) değiştirememeli; değişiklik yalnızca yerelde, yetkili kişiyle, doğrulama (imza/CRC) ve kayıtla yapılmalı. Haberleşme/güç kaybında güvenli durum. Her değişiklik sonrası fonksiyonel doğrulama kanıtlanmalı.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · AYSABAND 6 · Kenar Bantlama Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad	Grup	Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Üç şart: (1) Bileşen var mı: SBOM'da Component X aranır (PLC/HMI/sürücü firmware). (2) Sürüm 2.4 etkilenen aralıkta mı: cihaz sürümü ile CVE aralığı karşılaştırılır. (3) Açık ulaşılabilir mi: zafiyetli servis uzak erişim/ağ üzerinden erişilebilir mi (Z1/Z2 segmentasyonu). Üçü de 'evet' ise etkileniyoruz; biri 'hayır' ise risk düşer ama kayda alınır. CVSS 9.8 tek başına karar vermez.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, aktif istismar kanıtı yoksa. Önce erişimi kapatırız (uzak servis kapalı, güvenlik duvarı kuralı), yamayı planlı bakım penceresinde uygularız. Aktif saldırı varsa veya emniyet fonksiyonu etkilenmişse durdurma önceliklidir.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: test tezgâhı/yedek kontrolör veya ikiz PLC üzerinde, üretici onayı ve tam yedek alındıktan sonra; ardından planlı duruşta üretim makinesine, geri dönüş planıyla.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Yama Safety PLC, emniyet firmware'i, sürücü/STO-frenleme veya haberleşme zamanlamasına dokunuyor mu? Üretici sürüm notları ve değişiklik etki analiziyle anlaşılır. Dokunuyorsa veya şüphe varsa yeniden doğrulama: E-stop, kaput interlock, mil durma süresi ölçümü, emiş interlock testi; kanıt Evidence Pack'e eklenir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak servisi varsayılan kapalı tutmak; bölümlendirme + izinli liste güvenlik duvarı; zafiyetli servise erişimi engellemek; USB portlarını kilitlemek; ağ izleme/alarm; konfigürasyon yedeği ve bütünlük kontrolü; geçici manuel prosedür; risk kabul kaydı ve üretici yama takvimini izleme.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad | Grup | Tarih

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Kamera → YZ Modeli → OK / RED → Parametre → Robot

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	
Girdi manipüle edildi	
Confidence düştü	

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.

AYSABAND 6 — Safety 4.0 SWOT

Kenar Bantlama Makinesi · AİMSAD

GÜÇLÜ YÖNLER (S)

• Modüler ünite yapısı (ön freze, tutkal, kesme, kazıma vb.) güvenlik fonksiyonlarını ünite bazında tanımlamaya uygun
• Mobilya sektöründe yaygın ve bilinen makine tipi
• Yerli üretim: yazılım, parametre ve servis kontrolü üreticide (varsayım)
• Kaput interlock, E-stop ve emiş interlock gibi temel emniyet fonksiyonları mimaride tanımlı
• Uzak servis/diagnostik ile hızlı destek potansiyeli

ZAYIF YÖNLER (W)

• Uzak servis erişiminin güvenliği teyit edilmemiş (varsayım)
• Ortak hesap / varsayılan parola riski
• USB ve ERP/CAD-CAM iş dosyalarının doğrulanmaması
• Durma/frenleme süresi parametrelerinin dijital konfigürasyona bağlı olması
• SBOM ve CVE takibinin olgunlaşmamış olması olasılığı
• Olay müdahale ve kanıt saklama prosedürünün olgunlaşmamış olması

FIRSATLAR (O)

• CRA ve Makine Yönetmeliği için erken uyum = rekabet avantajı
• 'Secure by design' kenar bantlama makinesi olarak satış: müşteri güveni
• Güvenli uzak servis ve güncelleme hizmetinden servis geliri
• Endüstri 4.0: güvenli ERP/MES entegrasyonu ile fark yaratma
• AİMSAD/sektör işbirliği, ortak eğitim ve standartlaşma
• IEC 62443 ve ISO 13849 uyumlu referans mimariyle ihracat pazarlarında güven

TEHDİTLER (T)

• Fidye yazılımı / yetkisiz erişimle üretim durması veya emniyet fonksiyonunun bozulması
• CRA bildirim yükümlülükleri (24 saat / 72 saat / 14 gün) ve uyumsuzluk yaptırımları
• Tedarik zinciri zafiyetleri (PLC/sürücü/HMI firmware)
• Büyük rakiplerin (ör. SCM, Biesse) bağlantılı makinelerde güvenliği öne çıkarması
• Atölyelerde zayıf ağ ve USB hijyeni
• Siber kaynaklı kaza: ağır yaralanma, itibar ve hukuki sorumluluk

SWOT'tan çıkan 3 aksiyon

1) Uzak servisi jump server + VPN + MFA + kişisel hesap + varsayılan kapalı hale getir (Lab 2/4). 2) Safety PLC'yi ayrı zone'a al; kaput kilidi ve durma süresi parametrelerini ağdan değiştirilemez yap (Lab 1/4). 3) SBOM çıkar, CVE izlemeyi başlat; iş/reçete dosyalarını doğrula; yama sonrası safety yeniden doğrulama prosedürünü yaz (Lab 5).

Bu bir eğitim çıktısıdır; resmî denetim değildir. Varsayım içeren maddeler makinenin gerçek konfigürasyonuyla teyit edilmelidir.